



RAPPORT DE SÉCURITÉ

OWASP TOP 10 – 2021

OWASP Juice Shop

Réalisés par :

Hamdi Maissa

Reguigui Aymen

2025-2026

Table des matières

1. Résumé exécutif	1
2. A01:2021 – Contrôle d'Accès Défaillant (Broken Access Control)	2
3. A02:2021 – Défaillances Cryptographiques (Cryptographic Failures)	11
4. A03:2021 – Injection (Injection)	16
5. A04:2021 – Conception Non Sécurisée (Insecure Design)	20
6. A05:2021 – Mauvaise Configuration de Sécurité (Security Misconfiguration)	21
7. A06:2021 – Composants Vulnérables et Obsolètes (Vulnerable & Outdated Components)	23
8. A07:2021 – Authentification Défaillante (Identification & Authentication Failures)	24
9. A08:2021 – Défaillances d'Intégrité des Données et Logiciels (Software & Data Integrity Failures)	26
10. A09:2021 – Défaillances de Journalisation et de Surveillance (Security Logging & Monitoring Failures)	28
11. A10:2021 – Falsification des Requêtes Côté Serveur (Server-Side Request Forgery - SSRF)	36
12. Conclusion et plan d'action	39

Liste des tableaux

Tableau 1 : Récapitulatif des vulnérabilités OWASP Top 10 – 2021 (identifiant, sévérité, score CVSS)	1
--	---

Liste des figures

Figure 1 : Preuve – A01:2021 – Contrôle d'accès défaillant (capture n°1)	3
Figure 2 : Preuve – A01:2021 – Contrôle d'accès défaillant (capture n°2)	4
Figure 3 : Preuve – A01:2021 – Contrôle d'accès défaillant (capture n°3)	5
Figure 4 : Preuve – A01:2021 – Contrôle d'accès défaillant (capture n°4)	5
Figure 5 : Preuve – A01:2021 – Contrôle d'accès défaillant (capture n°5)	6
Figure 6 : Preuve – A01:2021 – Contrôle d'accès défaillant (capture n°6)	7
Figure 7 : Preuve – A01:2021 – Contrôle d'accès défaillant (capture n°7)	8
Figure 8 : Preuve – A01:2021 – Contrôle d'accès défaillant (capture n°8)	9
Figure 9 : Preuve – A01:2021 – Contrôle d'accès défaillant (capture n°9)	10
Figure 10 : Preuve – A01:2021 – Contrôle d'accès défaillant (capture n°10)	10
Figure 11 : Preuve – A02:2021 – Défaillances cryptographiques (capture n°1)	12
Figure 12 : Preuve – A02:2021 – Défaillances cryptographiques (capture n°2)	12
Figure 13 : Preuve – A02:2021 – Défaillances cryptographiques (capture n°3)	13
Figure 14 : Preuve – A02:2021 – Défaillances cryptographiques (capture n°4)	13
Figure 15 : Preuve – A02:2021 – Défaillances cryptographiques (capture n°5)	14
Figure 16 : Preuve – A02:2021 – Défaillances cryptographiques (capture n°6)	15
Figure 17 : Preuve – A02:2021 – Défaillances cryptographiques (capture n°7)	15
Figure 18 : Preuve – A03:2021 – Injection (capture n°1)	16
Figure 19 : Preuve – A03:2021 – Injection (capture n°2)	17
Figure 20 : Preuve – A03:2021 – Injection (capture n°3)	18
Figure 21 : Preuve – A03:2021 – Injection (capture n°4)	19
Figure 22 : Preuve – A04:2021 – Conception non sécurisée (capture n°1)	20

Liste des figures (suite)

Figure 23 : Preuve – A05:2021 – Mauvaise configuration de sécurité (capture n°1)	22
Figure 24 : Preuve – A05:2021 – Mauvaise configuration de sécurité (capture n°2)	22
Figure 25 : Preuve – A05:2021 – Mauvaise configuration de sécurité (capture n°3)	22
Figure 26 : Preuve – A07:2021 – Authentification défaillante (capture n°1)	24
Figure 27 : Preuve – A07:2021 – Authentification défaillante (capture n°2)	25
Figure 28 : Preuve – A08:2021 – Défaillances d'intégrité des données (capture n°1)	27
Figure 29 : Preuve – A09:2021 – Défaillances de journalisation et de surveillance (capture n°1)	28
Figure 30 : Preuve – A09:2021 – Défaillances de journalisation et de surveillance (capture n°2)	30
Figure 31 : Preuve – A09:2021 – Défaillances de journalisation et de surveillance (capture n°3)	31
Figure 32 : Preuve – A09:2021 – Défaillances de journalisation et de surveillance (capture n°4)	32
Figure 33 : Preuve – A09:2021 – Défaillances de journalisation et de surveillance (capture n°5)	33
Figure 34 : Preuve – A09:2021 – Défaillances de journalisation et de surveillance (capture n°6)	34
Figure 35 : Preuve – A09:2021 – Défaillances de journalisation et de surveillance (capture n°7)	34
Figure 36 : Preuve – A10:2021 – Falsification des requêtes côté serveur (SSRF) (capture n°1)	36
Figure 37 : Preuve – A10:2021 – Falsification des requêtes côté serveur (SSRF) (capture n°2)	37
Figure 38 : Preuve – A10:2021 – Falsification des requêtes côté serveur (SSRF) (capture n°3)	37

1. Résumé exécutif

OWASP Juice Shop est une application web délibérément vulnérable, conçue par l'OWASP Foundation à des fins de formation à la sécurité applicative. Elle intègre l'ensemble des vulnérabilités du classement OWASP Top 10 2021, ainsi que de nombreuses autres failles de sécurité réelles présentes dans les applications web modernes.

Cette analyse couvre les dix catégories de risques les plus critiques telles que définies par l'OWASP Top 10 2021. Pour chaque catégorie, nous documentons les vecteurs d'attaque spécifiques à Juice Shop, les impacts potentiels et les recommandations de remédiation.

#	Identifiant OWASP	Vulnérabilité	Sévérité	CVSS
1	A01:2021	Contrôle d'Accès Défaillant	Critique	9.8
2	A02:2021	Défaillances Cryptographiques	Élevé	7.5
3	A03:2021	Injection	Critique	9.8
4	A04:2021	Conception Non Sécurisée	Élevé	7.2
5	A05:2021	Mauvaise Configuration de Sécurité	Élevé	7.5
6	A06:2021	Composants Vulnérables et Obsolètes	Élevé	7.5
7	A07:2021	Authentification Défaillante	Critique	8.8

8	A08:2021	Défaillances d'Intégrité des Données et Logiciels	Élevé	7.2
9	A09:2021	Défaillances de Journalisation et de Surveillance	Moyen	5.4
10	A10:2021	Falsification des Requêtes Côté Serveur	Élevé	7.5

2. A01:2021 – Contrôle d'Accès Défaillant (Broken Access Control)

Sévérité : Critique

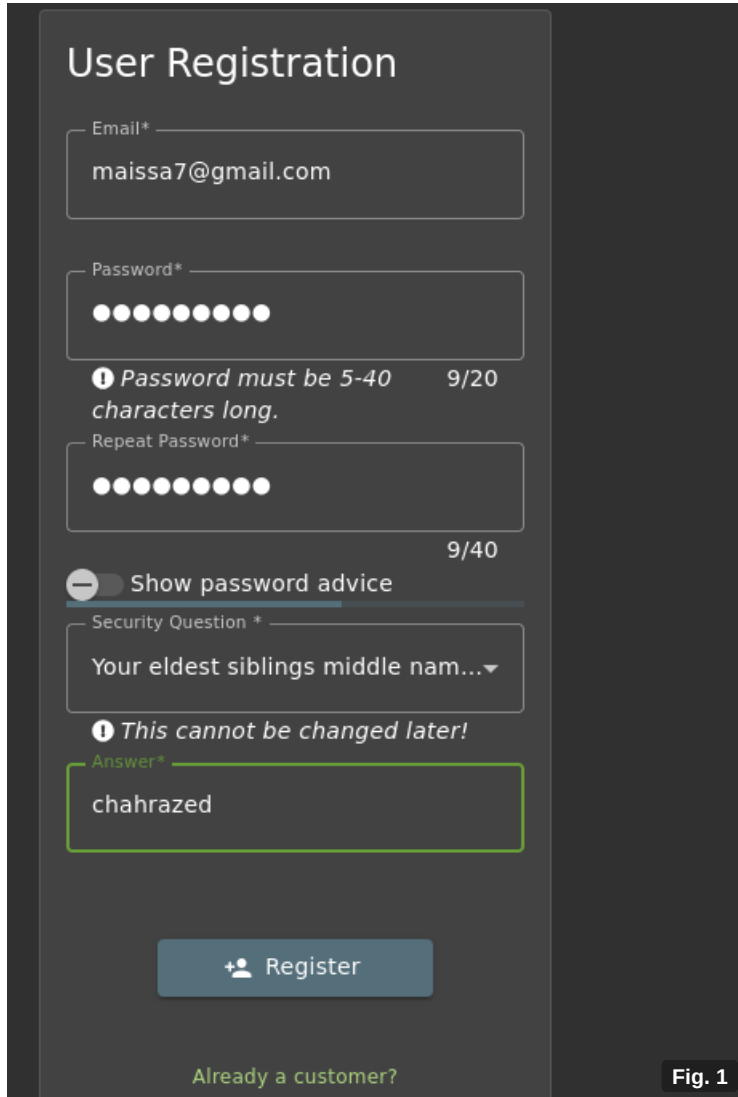
Score CVSS : 9.8

Description

Les restrictions sur les actions autorisées des utilisateurs authentifiés ne sont pas correctement appliquées. Dans Juice Shop, des utilisateurs peuvent accéder aux comptes d'autres utilisateurs, modifier des commandes qui ne leur appartiennent pas et accéder aux pages d'administration sans y être autorisés.

Preuve:

- **Accès direct à /administration sans être administrateur:**



The image shows a 'User Registration' form on a dark background. The form includes fields for Email, Password, Repeat Password, Security Question, and Answer. The Email field contains 'maissa7@gmail.com'. The Password field is masked with dots and has a strength indicator '9/20' and a message 'Password must be 5-40 characters long.'. The Repeat Password field is also masked with dots and has a strength indicator '9/40'. There is a 'Show password advice' toggle switch. The Security Question field contains 'Your eldest siblings middle nam...' with a dropdown arrow. Below it is a warning message 'This cannot be changed later!'. The Answer field contains 'chahrazed'. At the bottom is a 'Register' button with a user icon. A link 'Already a customer?' is at the bottom left. A caption 'Fig. 1' is at the bottom right.

User Registration

Email*
maissa7@gmail.com

Password*
●●●●●●●● 9/20
❗ Password must be 5-40 characters long.

Repeat Password*
●●●●●●●● 9/40

— Show password advice

Security Question *
Your eldest siblings middle nam...▼

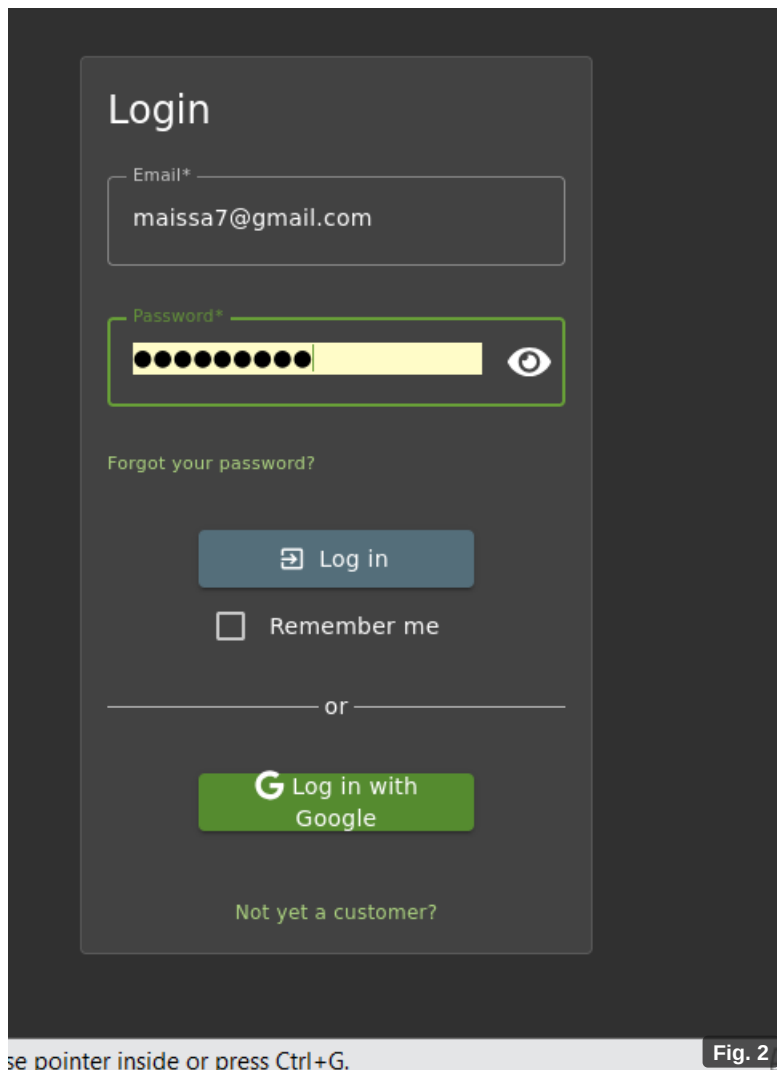
❗ This cannot be changed later!

Answer*
chahrazed

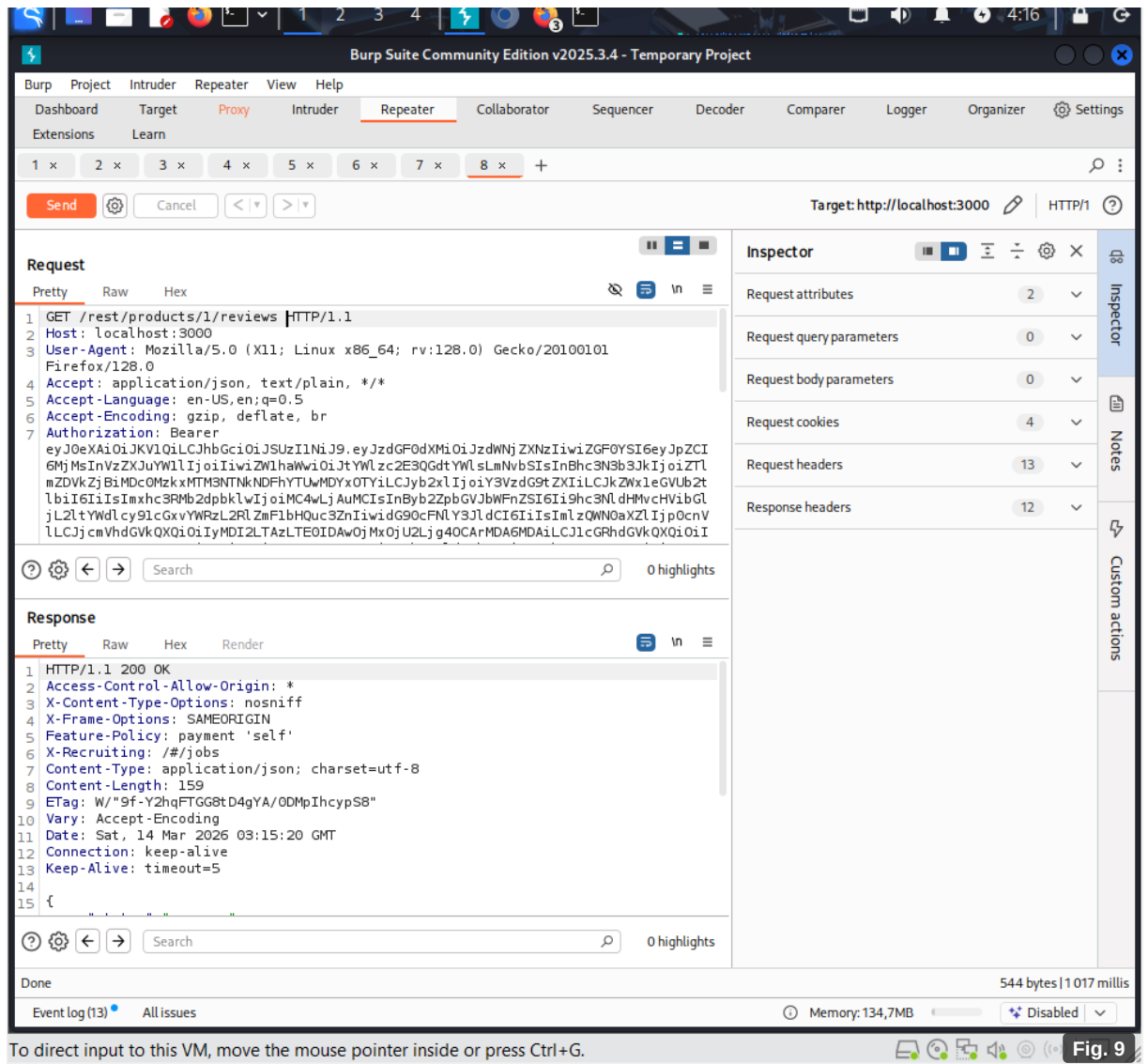
+ Register

Already a customer?

Fig. 1







la réponse contient :message;author→ les avis des autres utilisateurs apparaissent sans restriction, cela signifie :l'application ne vérifie pas les autorisations. → C'est une vulnérabilité Broken Access Control.

Impact

Un attaquant peut accéder, modifier ou supprimer des données appartenant à d'autres utilisateurs, ou effectuer des actions nécessitant des droits élevés.

Recommandations de remédiation

- Implémenter un contrôle d'accès basé sur les rôles (RBAC)
- Valider les droits d'accès côté serveur à chaque requête
- Refuser l'accès par défaut sauf pour les ressources publiques
- Journaliser les échecs de contrôle d'accès et alerter les administrateurs

3. A02:2021 – Défaillances Cryptographiques (Cryptographic Failures)

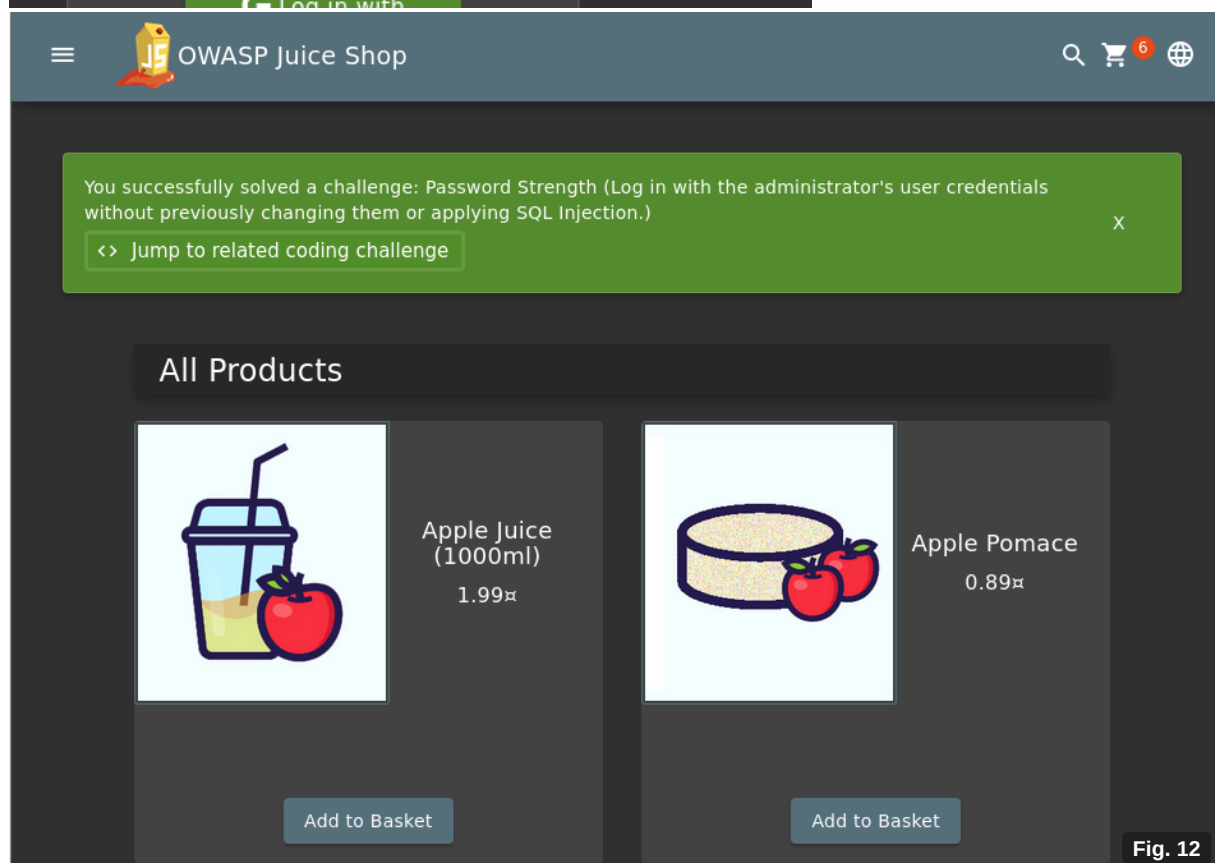
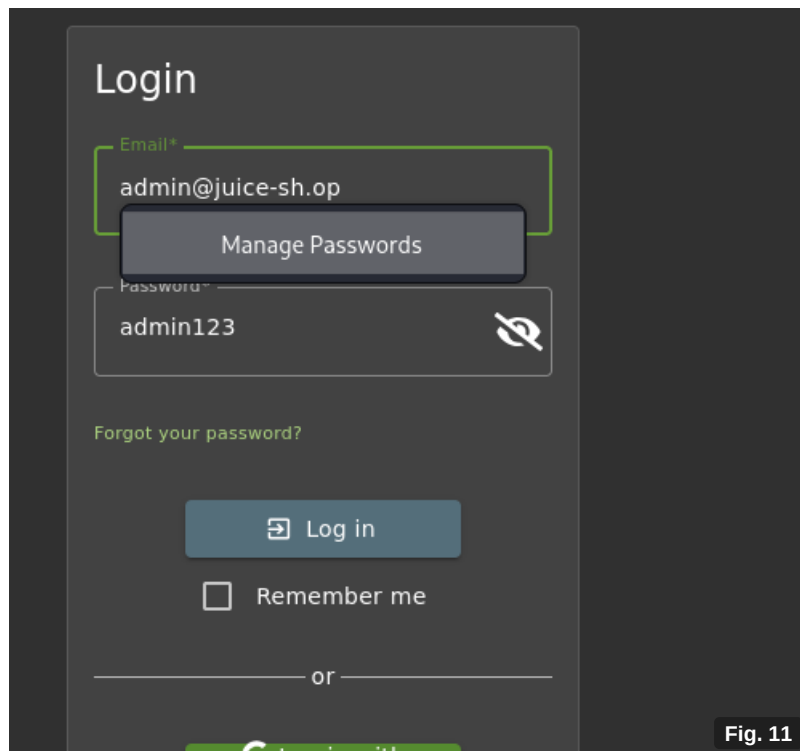
Sévérité : Élevé

Score CVSS : 7.5

Description

Juice Shop utilise des algorithmes cryptographiques obsolètes ou faibles pour stocker les mots de passe et protéger les données sensibles. Les mots de passe sont souvent hachés avec MD5 ou SHA1 sans sel, ce qui les rend vulnérables aux attaques par table arc-en-ciel.

Preuve:



l'application accepte un mot de passe faible → Cryptographic Failure.

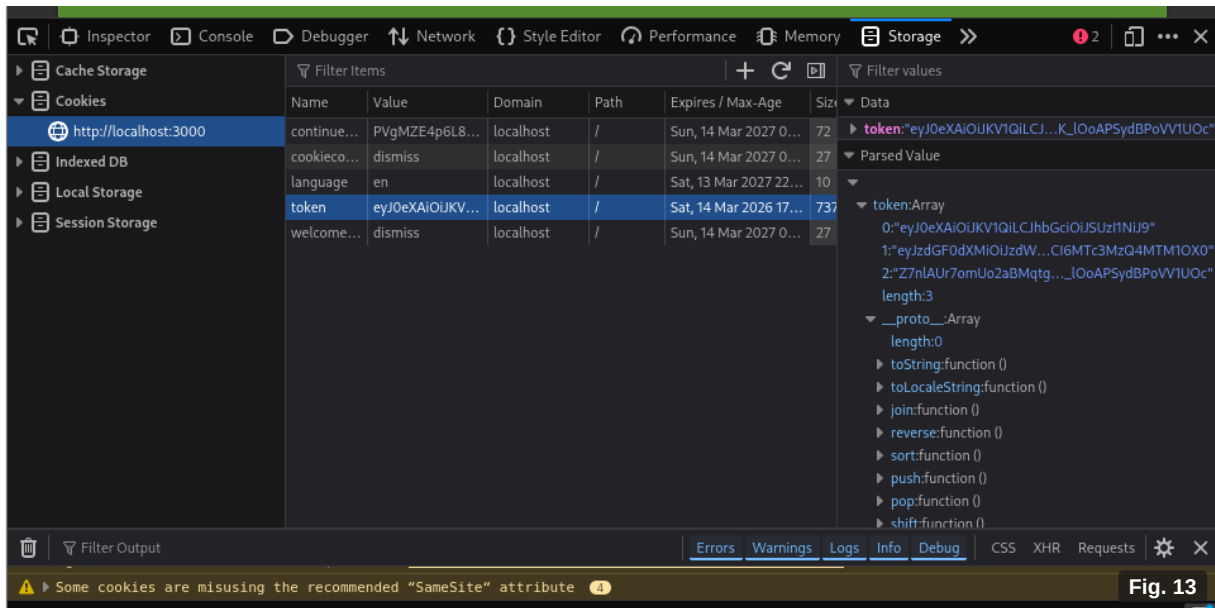


Fig. 13

Exposition des données sensibles

L'API retourne :

- email
- hash du mot de passe
- rôle admin

Un attaquant peut récupérer ces informations.

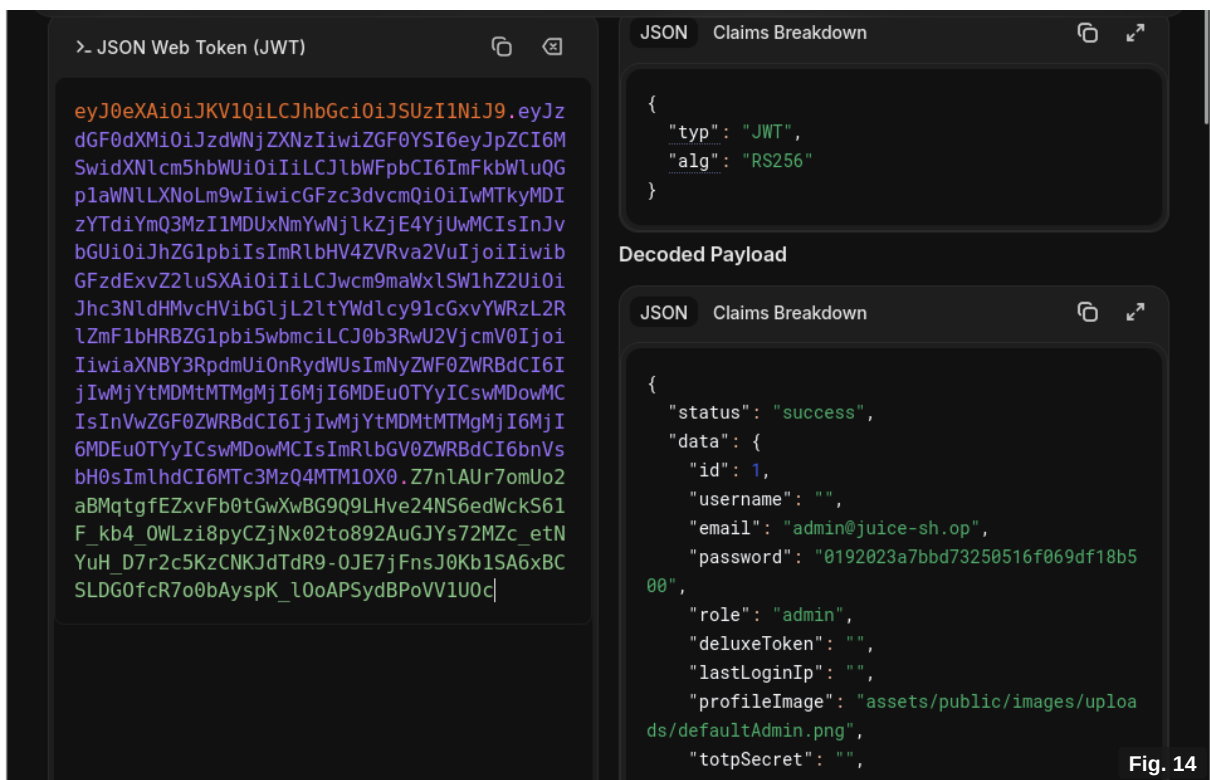


Fig. 14

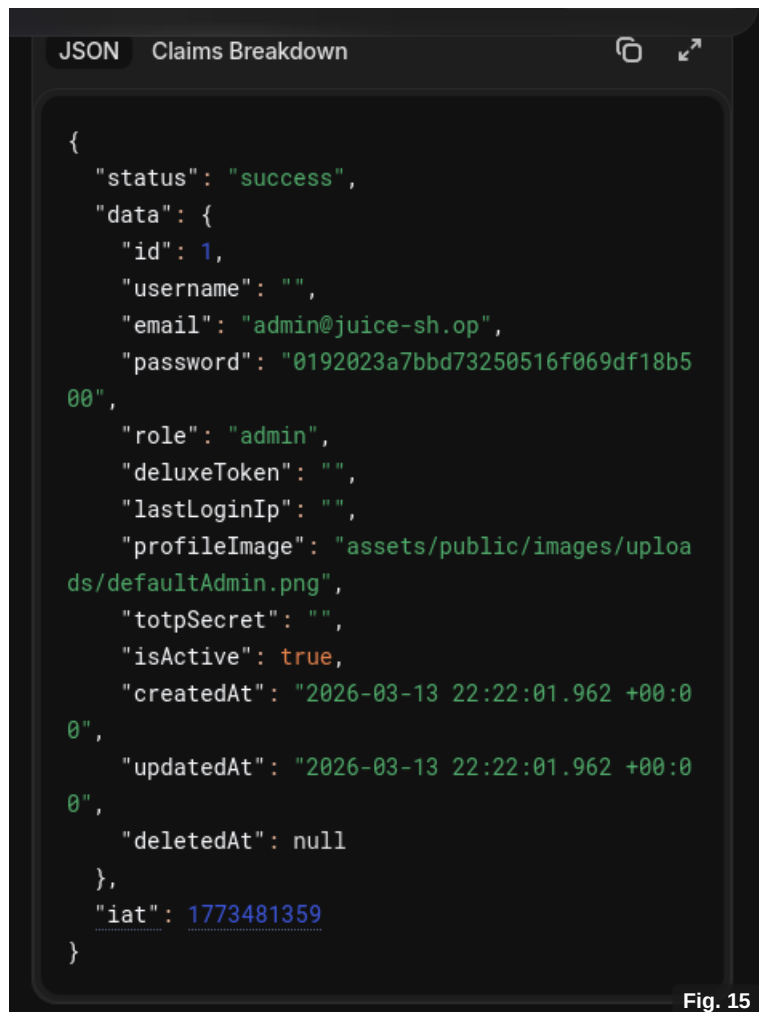


Fig. 15

Le problème principal est :

Hash faible (MD5)

Avec des outils comme :

- Hashcat

Le hash peut être cassé très rapidement.

```
(maissa@kali)-[~]
$ sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
echo 0192023a7bbd73250516f069df18b500 > hash.txt
hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt
gzip: /usr/share/wordlists/rockyou.txt.gz: No such file or directory
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, L
LVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: cpu-haswell-13th Gen Intel(R) Core(TM) i5-13500H, 2898/5861 MB (
1024 MB allocatable), 8MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
```

Fig. 16

```
Dictionary cache building /usr/share/wordlists/rockyou.txt: 33553434 bytes (2
Dictionary cache building /usr/share/wordlists/rockyou.txt: 100660302 bytes (
Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords..: 14344392
* Bytes.....: 139921507
* Keyspace..: 14344385
* Runtime...: 1 sec

0192023a7bbd73250516f069df18b500:admin123

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MD5)
Hash.Target.....: 0192023a7bbd73250516f069df18b500
Time.Started.....: Sat Mar 14 11:21:03 2026 (0 secs)
Time.Estimated...: Sat Mar 14 11:21:03 2026 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 684.6 kH/s (0.55ms) @ Accel:512 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 90112/14344385 (0.63%)
Rejected.....: 0/90112 (0.00%)
```

Fig. 17

Impact

Exposition des mots de passe, données personnelles, informations de paiement et jetons d'authentification à des acteurs malveillants.

Recommandations de remédiation

- Utiliser bcrypt, Argon2 ou PBKDF2 pour le hachage des mots de passe
- Chiffrer toutes les données sensibles au repos et en transit (TLS 1.3)
- Utiliser des algorithmes modernes (AES-256, SHA-256 minimum)
- Ne jamais stocker de données sensibles inutilement

4. A03:2021 – Injection (Injection)

Sévérité : Critique

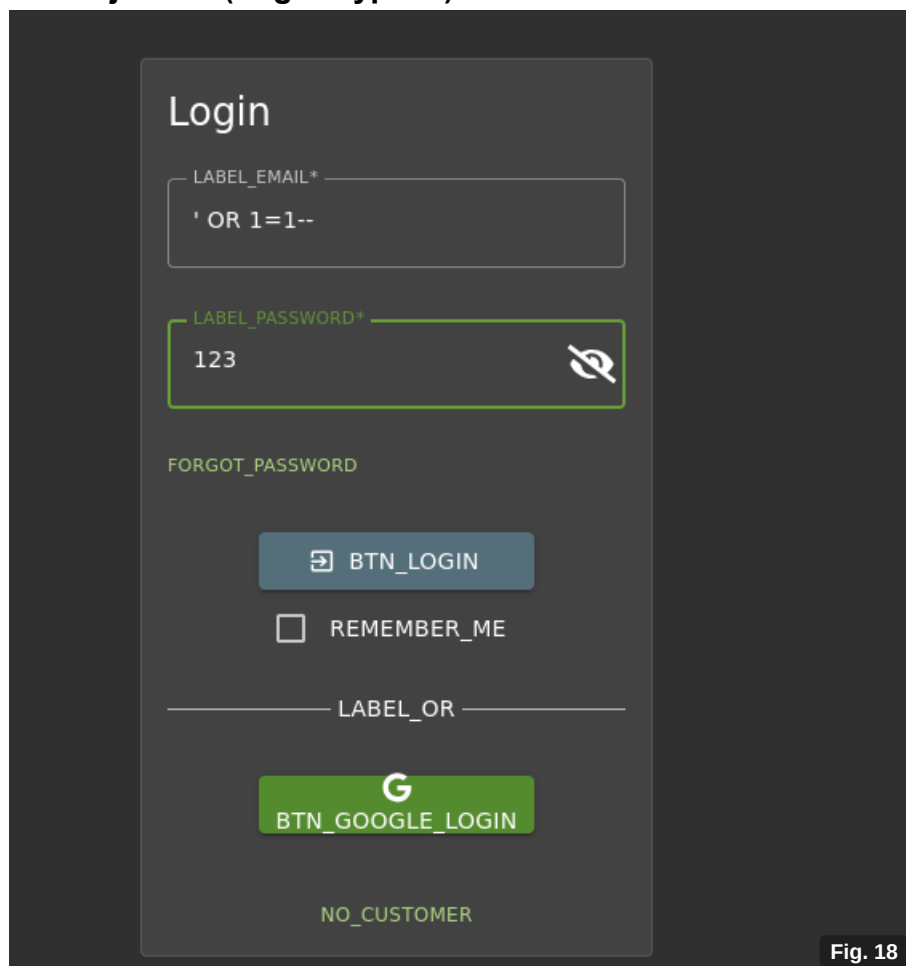
Score CVSS : 9.8

Description

Juice Shop est vulnérable à plusieurs types d'injection, notamment SQL, NoSQL et de commandes système. Ces failles permettent à un attaquant de manipuler les requêtes de base de données et d'exécuter des commandes arbitraires sur le serveur.

Preuve:

SQL Injection (Login Bypass):



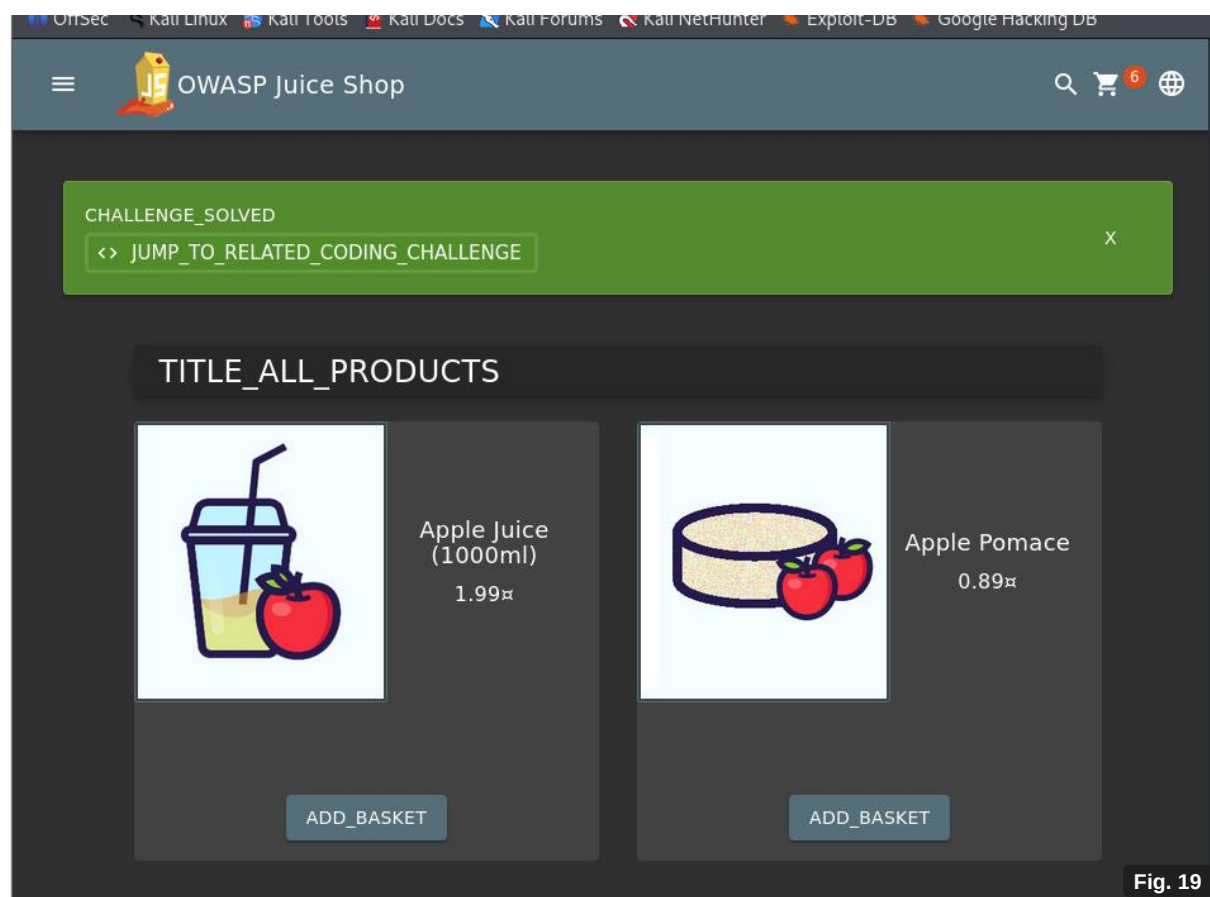


Fig. 19

XSS Injection (Feedback):

Customer Feedback

Author

***in@juice-sh.op

Comment*

`<script>alert('XSS')</script>`

Max. 160 characters 29/160

Rating ☒

CAPTCHA: What is $6+4+7$?

Result*

17

Submit

Fig. 20

The image shows a 'Customer Feedback' form on a dark background. The form contains the following elements: a title 'Customer Feedback', an 'Author' field with the value '***in@juice-sh.op', a 'Comment*' text area with a character count 'Max. 160 characters' and '0/160', a 'Rating' section with a green circle and a horizontal bar, a CAPTCHA question 'What is 5+2-8 ?', a 'Result*' field, and a 'Submit' button. Below the form, a white alert box displays the message 'Thank you for your feedback.' with a close button 'X'. The label 'Fig. 21' is located at the bottom right of the form area.

Une fenêtre (alert) apparaît.

Cela signifie que le script est exécuté dans le navigateur.

Impact

Contournement de l'authentification, extraction complète de la base de données, modification ou suppression de données, exécution de commandes système.

Recommandations de remédiation

- Valider et assainir toutes les entrées utilisateur
- Appliquer le principe de moindre privilège pour les comptes de base de données
- Utiliser un WAF (Web Application Firewall) en complément

5. A04:2021 – Conception Non Sécurisée (Insecure Design)

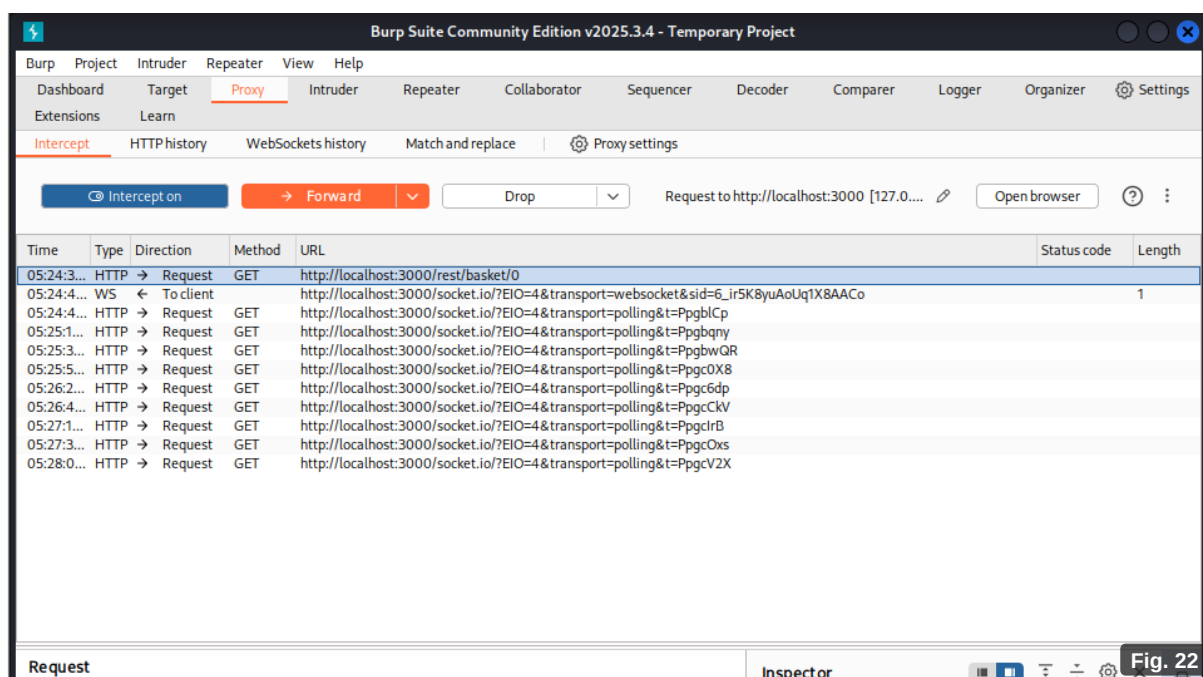
Sévérité : Élevé

Score CVSS : 7.2

Description

Juice Shop présente des défauts de conception fondamentaux qui ne peuvent être corrigés par une simple implémentation sécurisée. La logique métier présente des failles qui permettent des abus non prévus comme commander gratuitement ou manipuler les prix.

Preuve:



Impact

Fraudes financières, contournement des règles métier, exploitation des processus non sécurisés.

Recommandations de remédiation

- Intégrer la sécurité dès la phase de conception (sécurité par conception)
- Effectuer une modélisation des menaces

- Valider la logique métier côté serveur
- Implémenter des contrôles anti-fraude et des limites de débit

6. A05:2021 – Mauvaise Configuration de Sécurité (Security Misconfiguration)

Sévérité : Élevé

Score CVSS : 7.5

Description

Juice Shop expose des configurations par défaut non sécurisées, des répertoires listés, des comptes par défaut non modifiés et des fonctionnalités activées inutilement. Les messages d'erreur révèlent des informations sensibles sur l'infrastructure.

Preuve:

```
(maissa@kali)-[~]
$ gobuster dir -u http://localhost:3000 -w /usr/share/wordlists/dirb/common.txt --exclude-length 75002

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://localhost:3000
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] Exclude Length: 75002
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/api (Status: 500) [Size: 3011]
/apis (Status: 500) [Size: 3013]
/assets (Status: 301) [Size: 156] [→ /assets/]
/ftp (Status: 200) [Size: 11298]
/media (Status: 301) [Size: 155] [→ /media/]
/profile (Status: 500) [Size: 1043]
/promotion (Status: 200) [Size: 6459]
/redirect (Status: 500) [Size: 3113]
/rest (Status: 500) [Size: 3013]
```

Fig. 23

```
/rest (Status: 500) [Size: 3013]
/restaurants (Status: 500) [Size: 3027]
/restore (Status: 500) [Size: 3019]
/restored (Status: 500) [Size: 3021]
/restricted (Status: 500) [Size: 3025]
/robots.txt (Status: 200) [Size: 28]
/video (Status: 200) [Size: 10075518]
/Video (Status: 200) [Size: 10075518]
Progress: 4614 / 4615 (99.98%)

Finished
```

Fig. 24

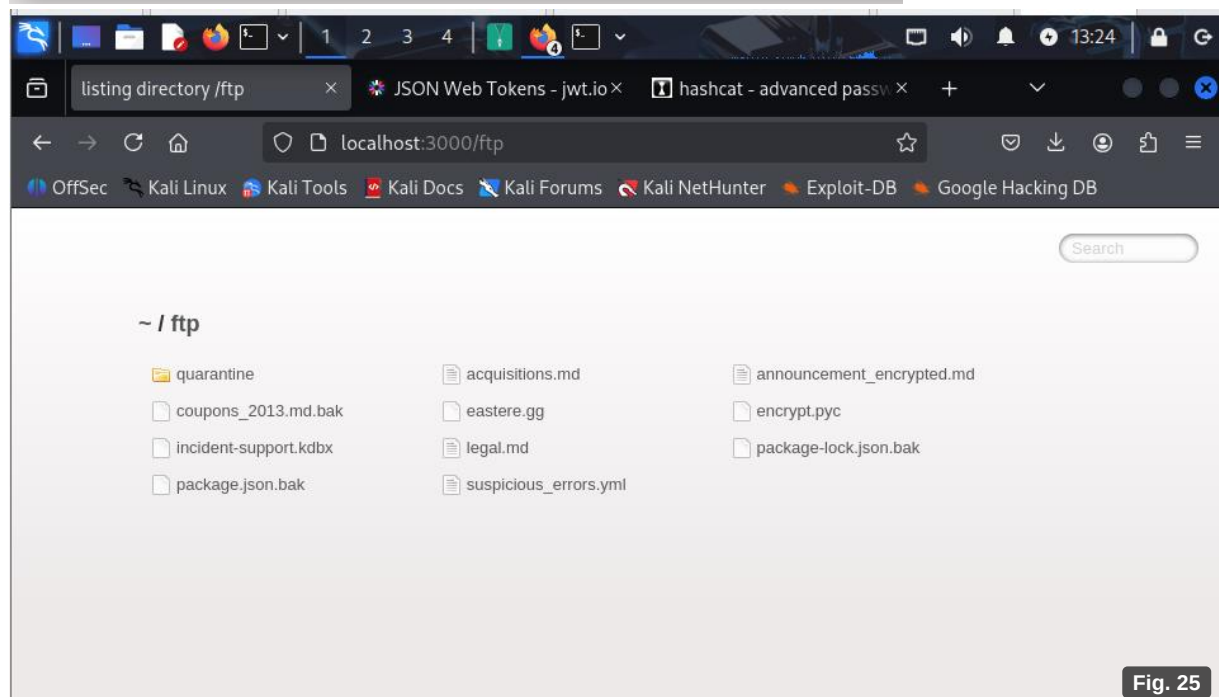


Fig. 25

Impact

Exposition de fichiers sensibles, accès non autorisé à des fonctionnalités administratives, reconnaissance facilitée pour les attaquants.

Recommandations de remédiation

- Mettre en place un processus de durcissement systématique des configurations
- Configurer correctement tous les en-têtes de sécurité HTTP
- Désactiver les fonctionnalités, services et comptes inutiles
- Automatiser la vérification des configurations avec des outils SAST/DAST

7. A06:2021 – Composants Vulnérables et Obsolètes (Vulnerable & Outdated Components)

Sévérité : Élevé

Score CVSS : 7.5

Description

Juice Shop utilise intentionnellement des dépendances npm obsolètes et vulnérables. Cela comprend des versions de bibliothèques JavaScript affectées par des vulnérabilités répertoriées (CVE), susceptibles d'être exploitées pour compromettre l'application.

Preuve:

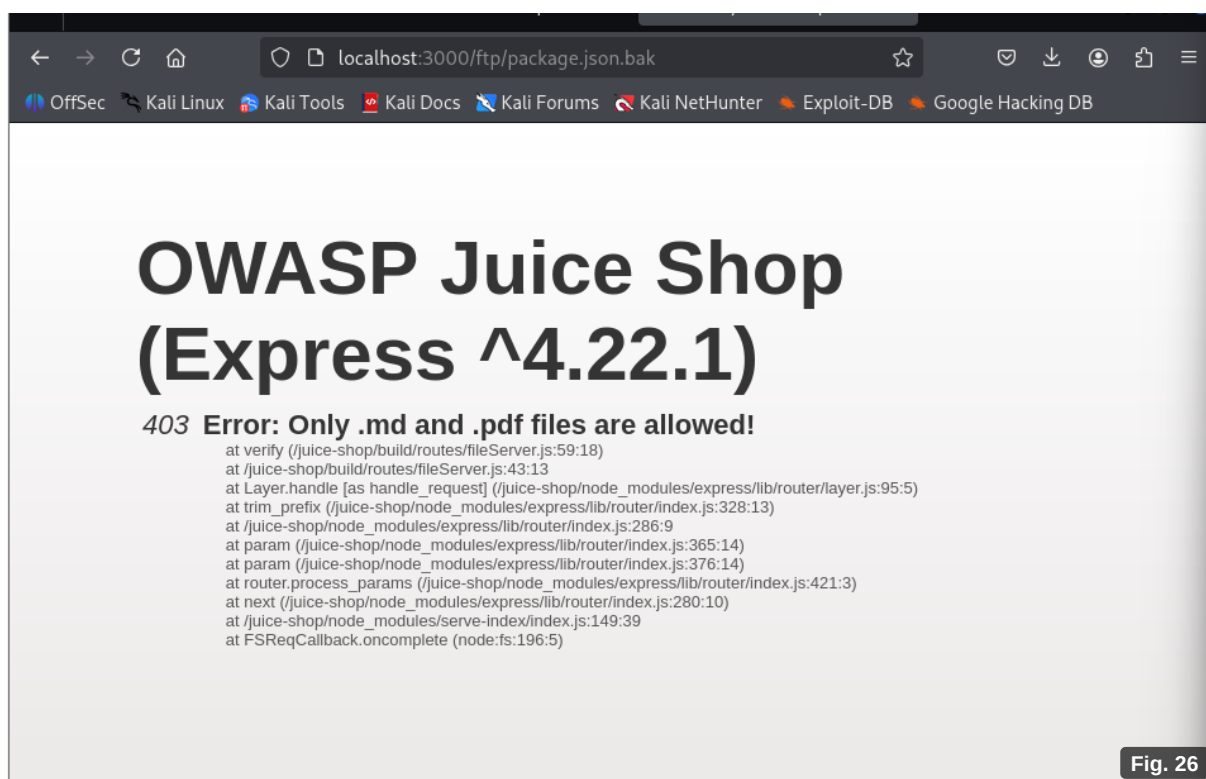


Fig. 26

Cette application utilise Express 4.22.1 .

Impact

Exécution de code arbitraire, déni de service, divulgation d'informations via les vulnérabilités des composants tiers.

Recommandations de remédiation

- Inventorier tous les composants et leurs versions (SBOM)
- Surveiller en continu les CVE via des outils comme Snyk ou OWASP Dependency-Check
- Mettre à jour régulièrement les dépendances
- Utiliser uniquement des composants maintenus activement

8. A07:2021 – Authentification Défaillante (Identification & Authentication Failures)

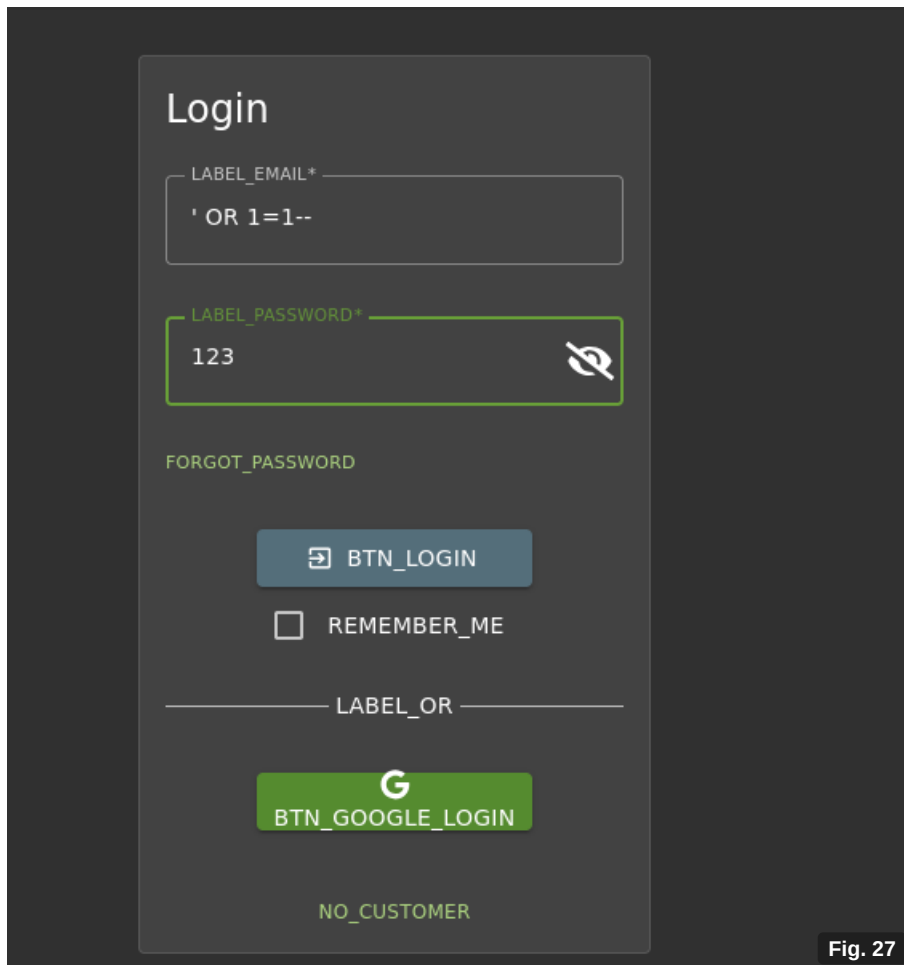
Sévérité : Critique

Score CVSS : 8.8

Description

Juice Shop présente de nombreuses failles d'authentification : absence de protection contre les attaques par force brute, mécanisme de récupération de compte vulnérable, jetons JWT manipulables, et absence d'authentification multi-facteurs.

Preuve:



Impact

Usurpation d'identité, prise de contrôle de compte, élévation de privilèges, accès non autorisé aux données.

Recommandations de remédiation

- Implémenter un verrouillage progressif des comptes et une limitation du débit
- Utiliser des algorithmes JWT sécurisés (RS256, ES256)
- Activer l'authentification multi-facteurs (MFA)

- Invalider correctement les sessions lors de la déconnexion

9. A08:2021 – Défaillances d'Intégrité des Données et Logiciels (Software & Data Integrity Failures)

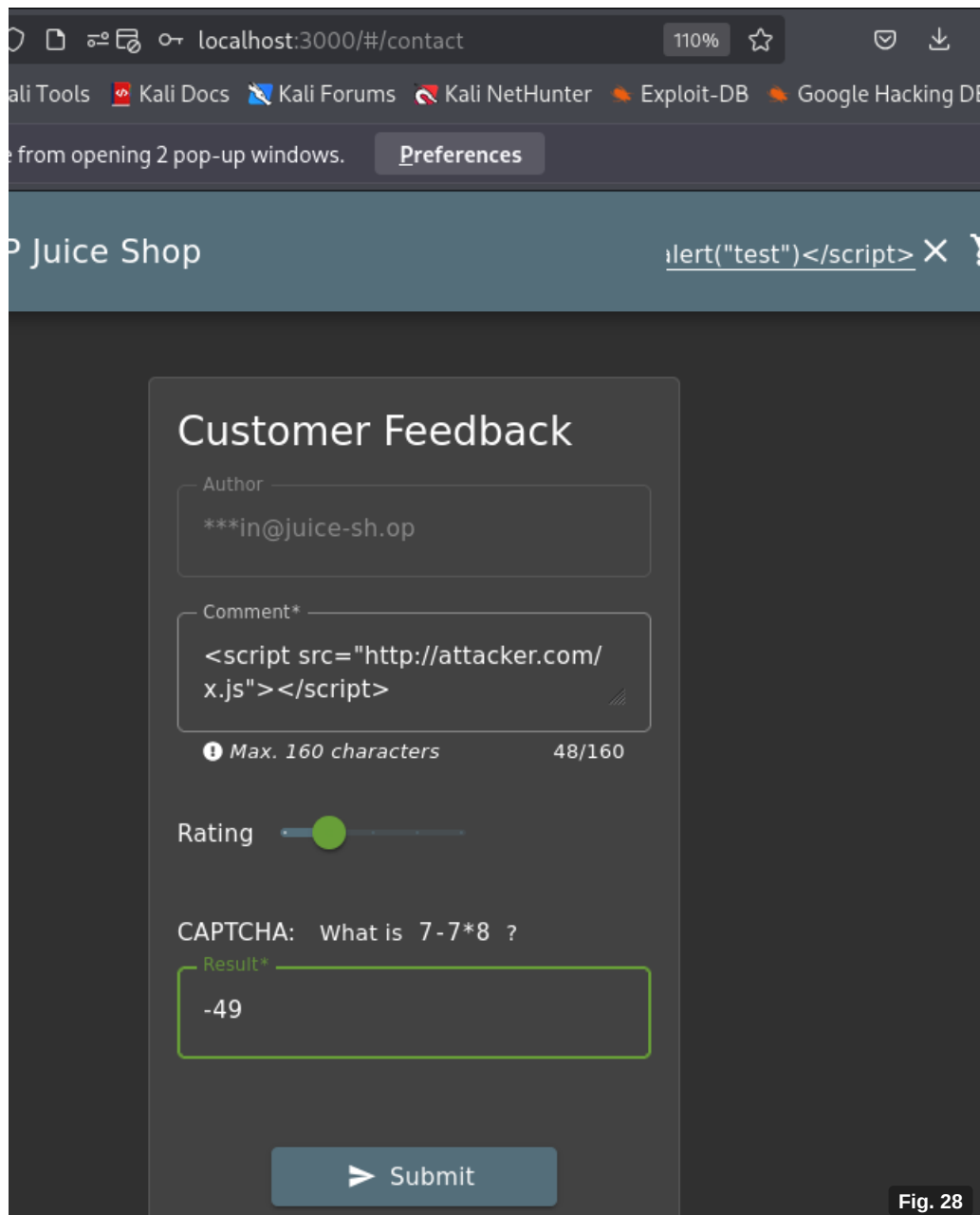
Sévérité : Élevé

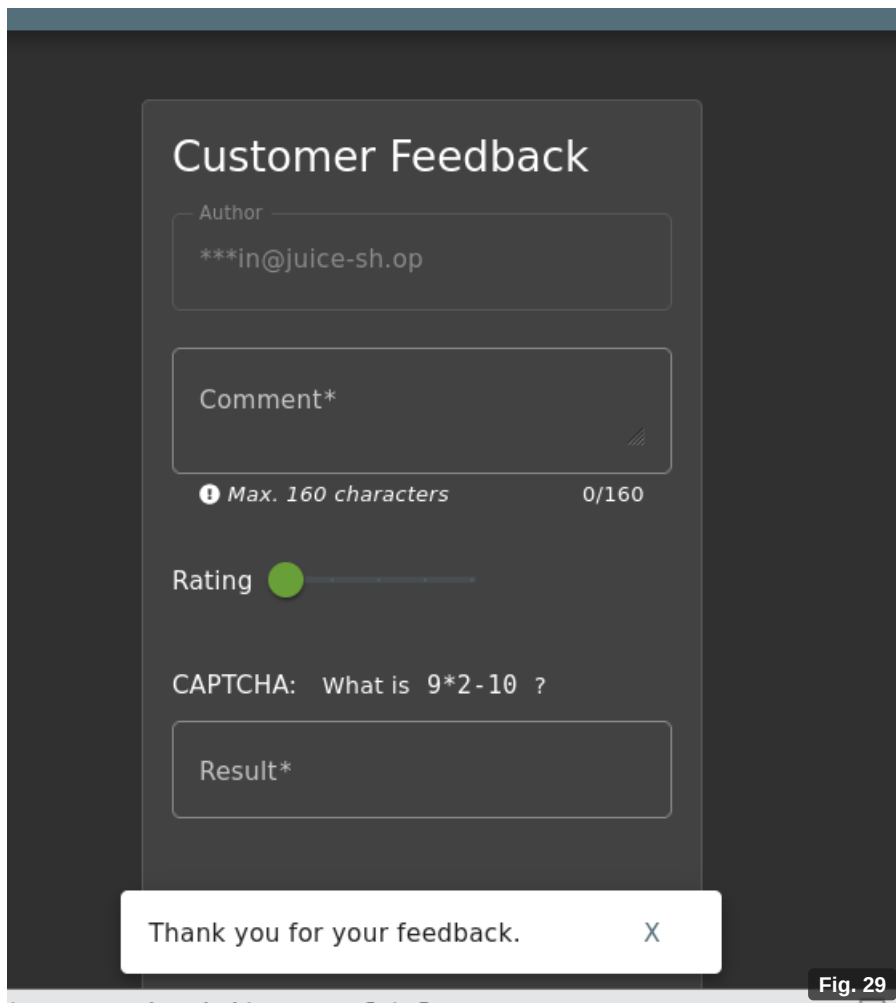
Score CVSS : 7.2

Description

Juice Shop ne vérifie pas l'intégrité des mises à jour de logiciels et des données critiques. Les processus automatisés de mise à jour et les pipelines d'intégration continue ne sont pas sécurisés, ce qui permet l'injection de code malveillant.

Preuve:





Impact

Injection de code malveillant, élévation de privilèges via prototype pollution, compromission de la chaîne d'approvisionnement logicielle.

Recommandations de remédiation

- Vérifier les signatures numériques des mises à jour
- Utiliser des attributs SRI (Subresource Integrity) pour les ressources externes
- Désactiver la désérialisation des types non fiables
- Sécuriser les pipelines d'intégration et de déploiement continus avec des contrôles d'intégrité

10. A09:2021 – Défaillances de Journalisation et de Surveillance (Security Logging & Monitoring Failures)

Sévérité : Moyen

Score CVSS : 5.4

Description

Juice Shop ne journalise pas correctement les événements de sécurité et ne dispose pas de mécanismes de détection d'intrusion. Les attaques peuvent rester inaperçues pendant de longues périodes, laissant les attaquants opérer librement.

Preuve:

Login

Email*
admin@juice-sh.op

Password*
123456 

[Forgot your password?](#)

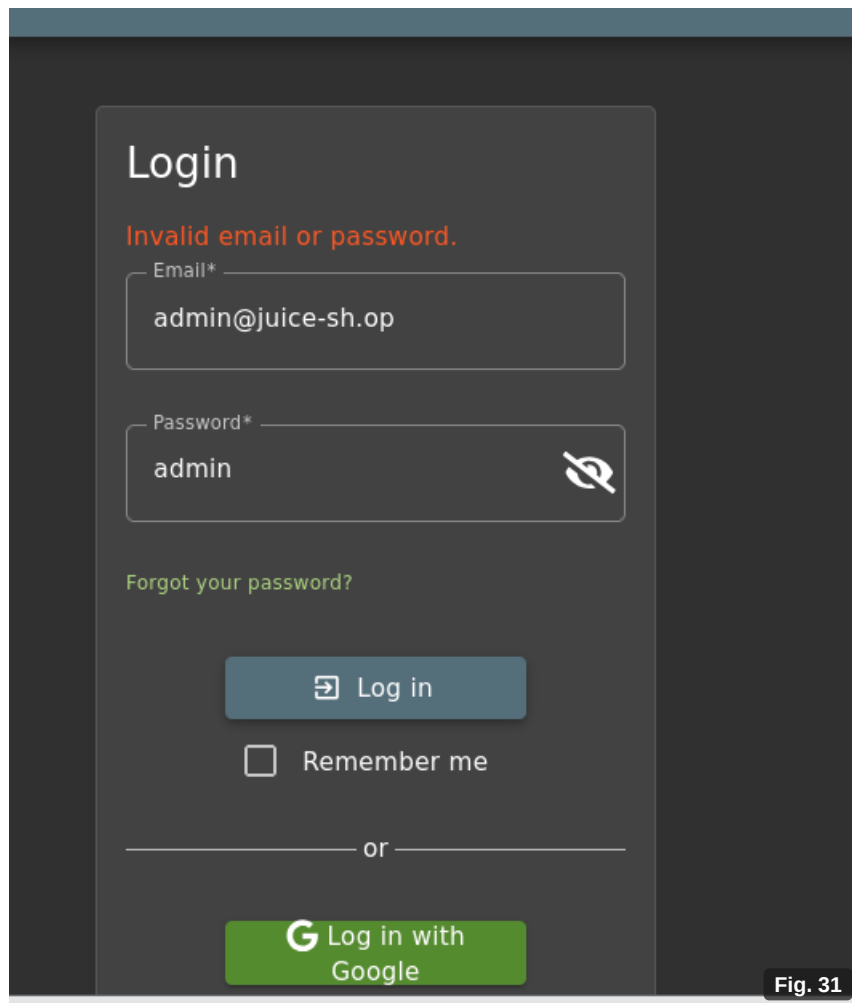
 Log in

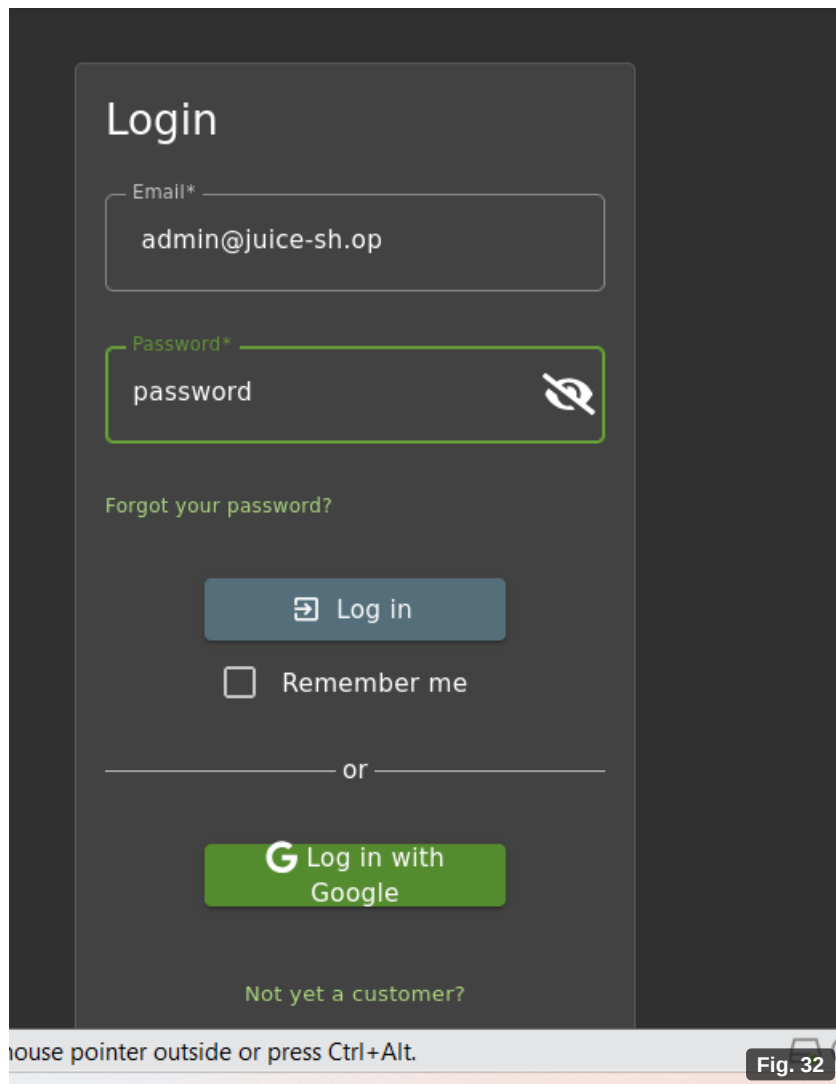
☐ Remember me

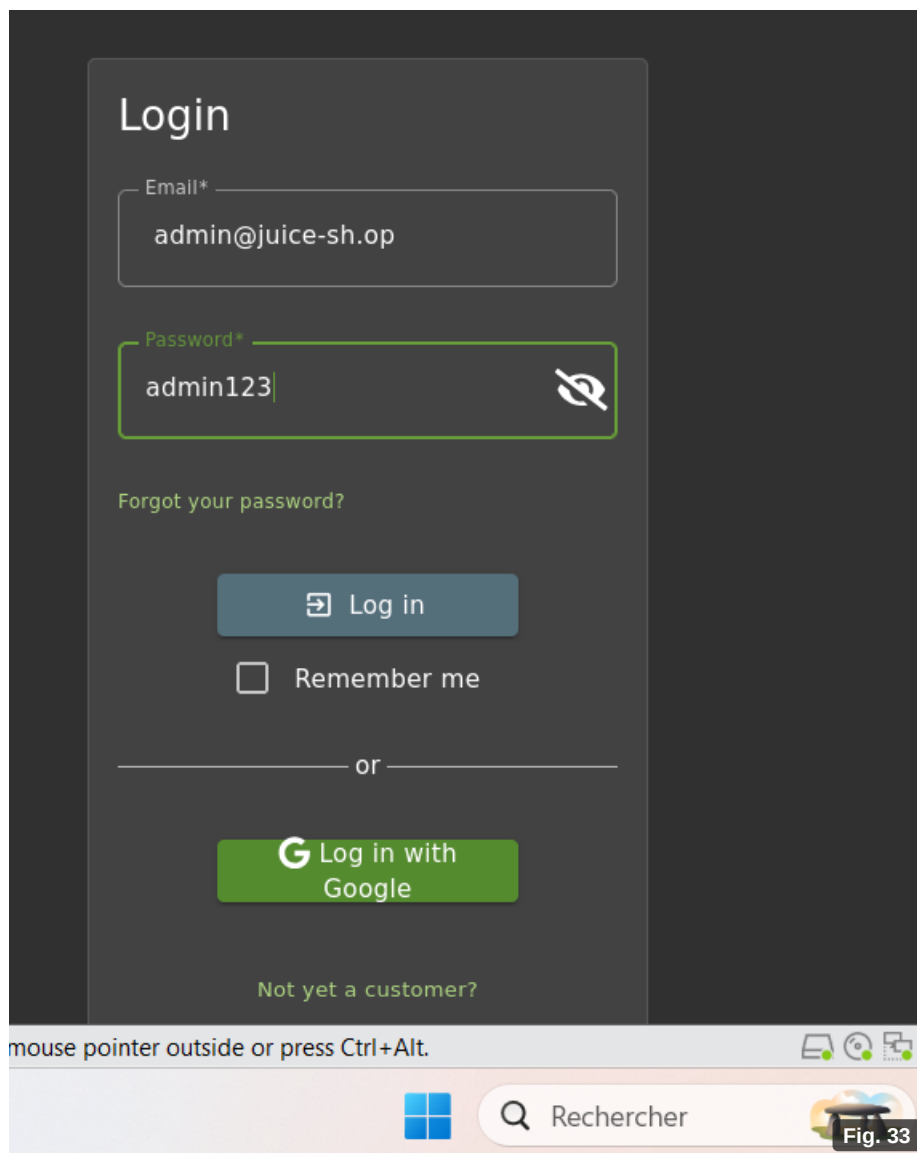
— or —

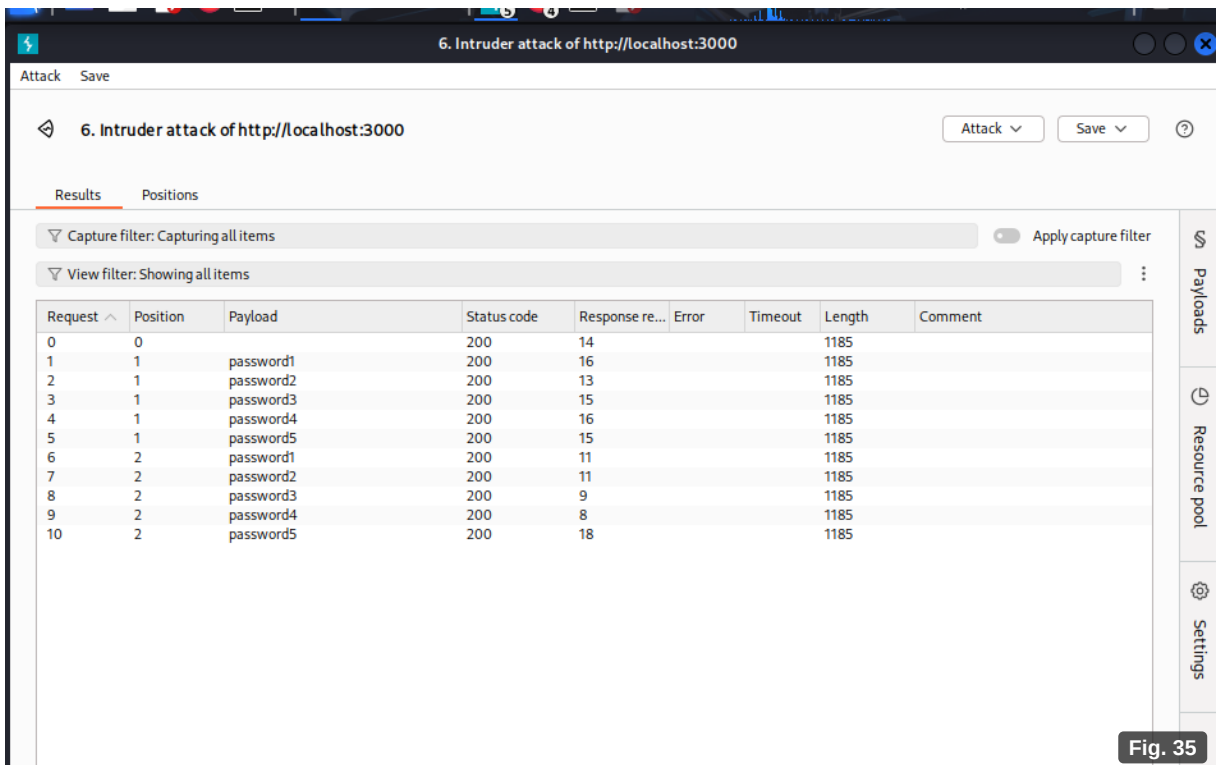
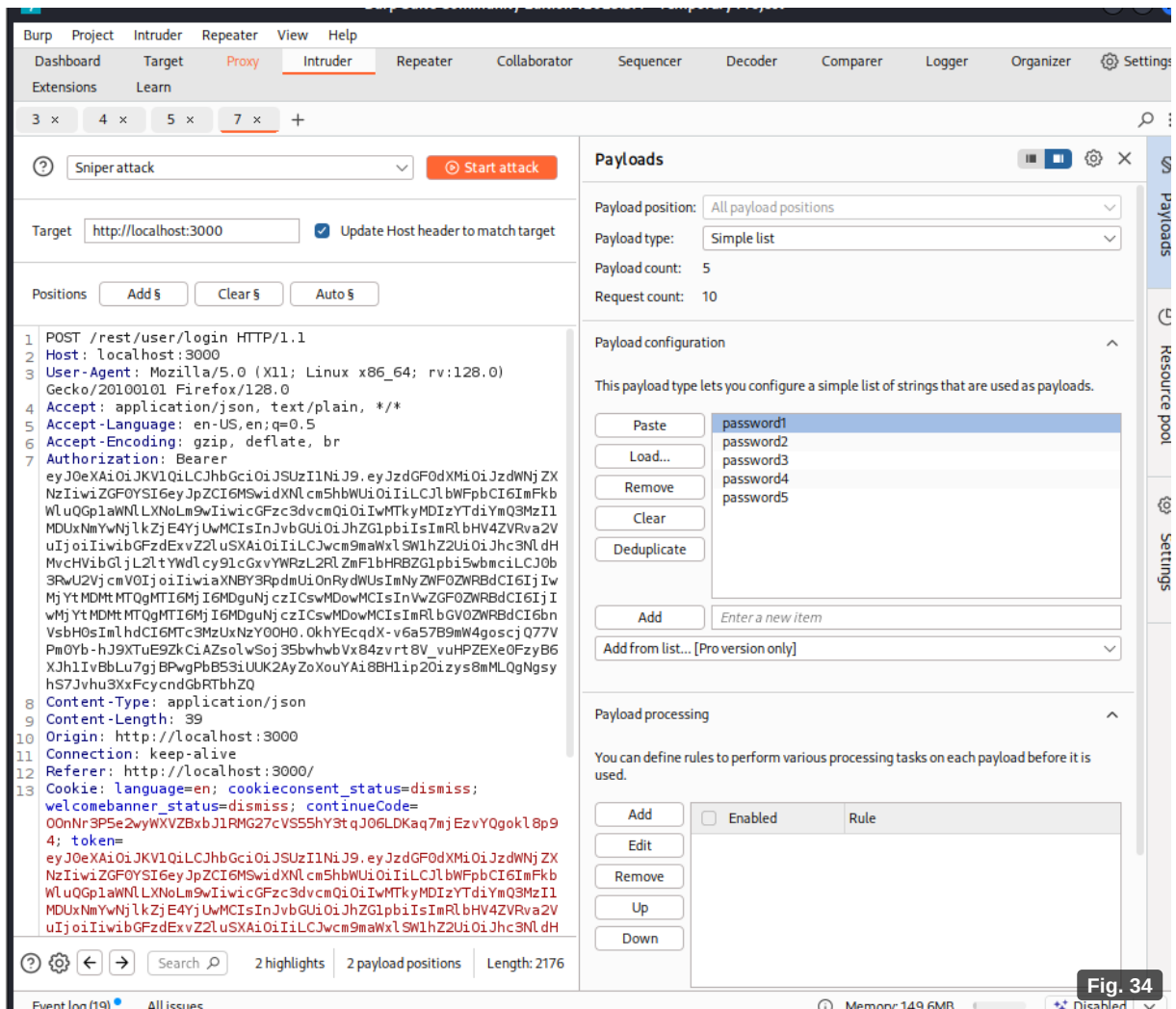
 Log in with Google

Fig. 30









l'application :

ne bloque pas

ne limite pas les essais

→ cela montre un Security Logging & Monitoring Failure.

Impact

Détection tardive des violations de données, difficulté à analyser les incidents de sécurité, conformité réglementaire non respectée (RGPD).

Recommandations de remédiation

- Journaliser tous les événements de sécurité (connexions, accès refusés)
- Mettre en place un SIEM pour la corrélation et l'analyse des journaux d'événements
- Configurer des alertes en temps réel pour les anomalies
- Conserver les journaux de manière sécurisée et vérifiable

11. A10:2021 – Falsification des Requêtes Côté Serveur (Server-Side Request Forgery - SSRF)

Sévérité : Élevé

Score CVSS : 7.5

Description

Juice Shop est vulnérable aux attaques SSRF via les fonctionnalités qui récupèrent des ressources externes. Un attaquant peut forcer le serveur à effectuer des requêtes vers des ressources internes non accessibles depuis l'extérieur.

Preuve:

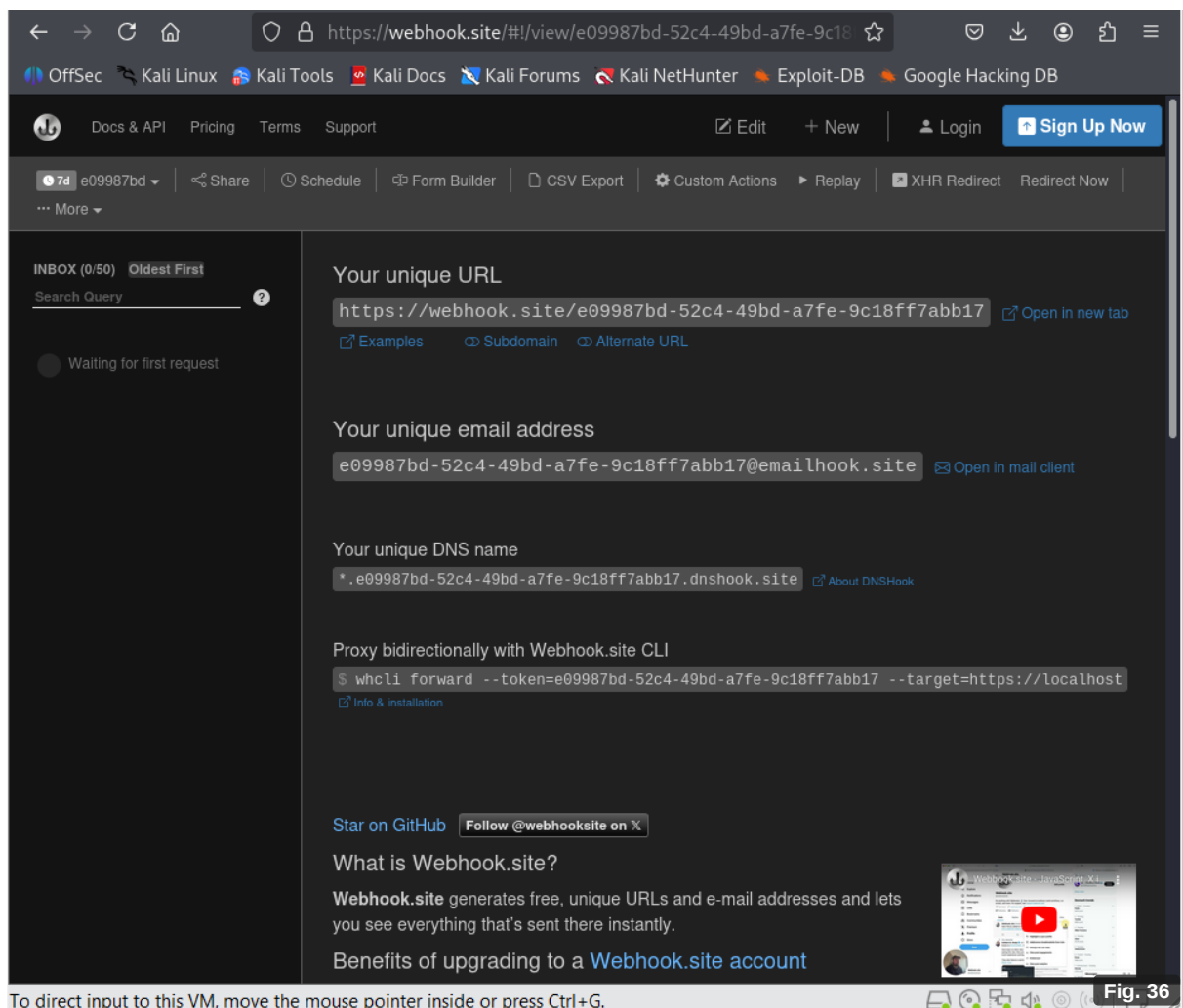


Fig. 36

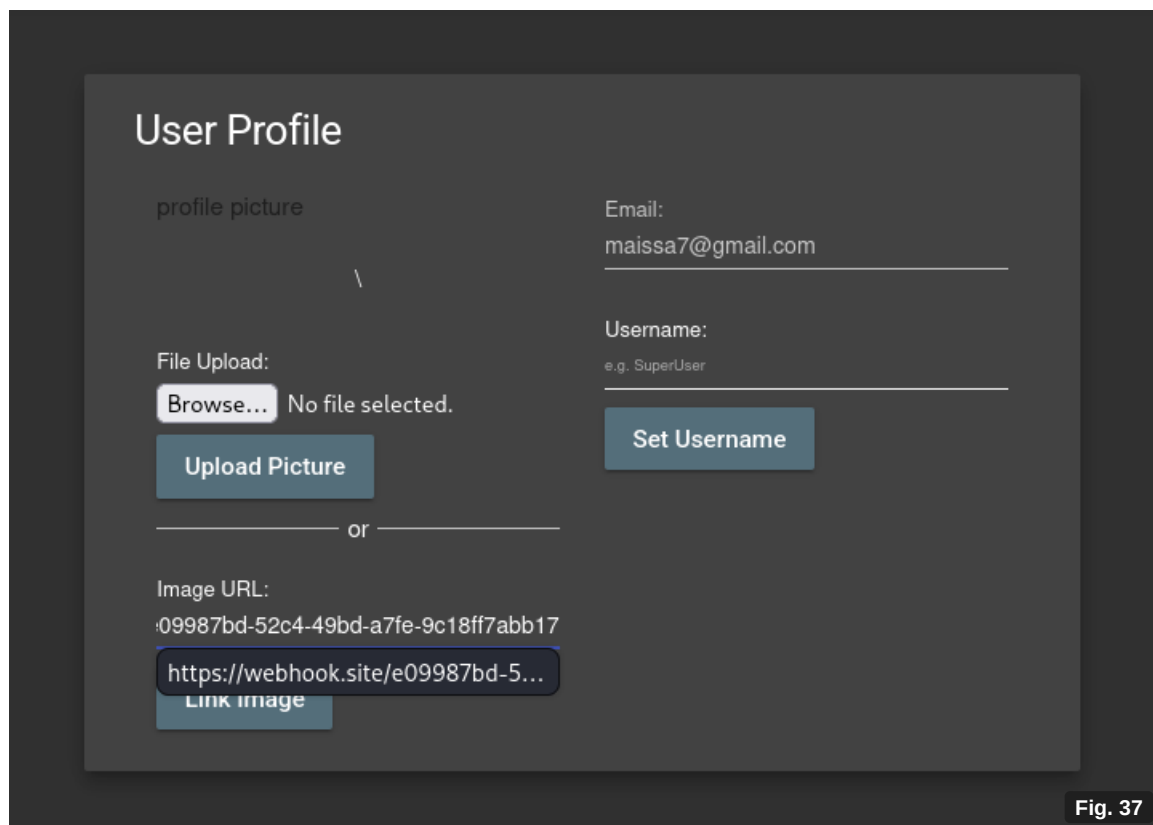


Fig. 37

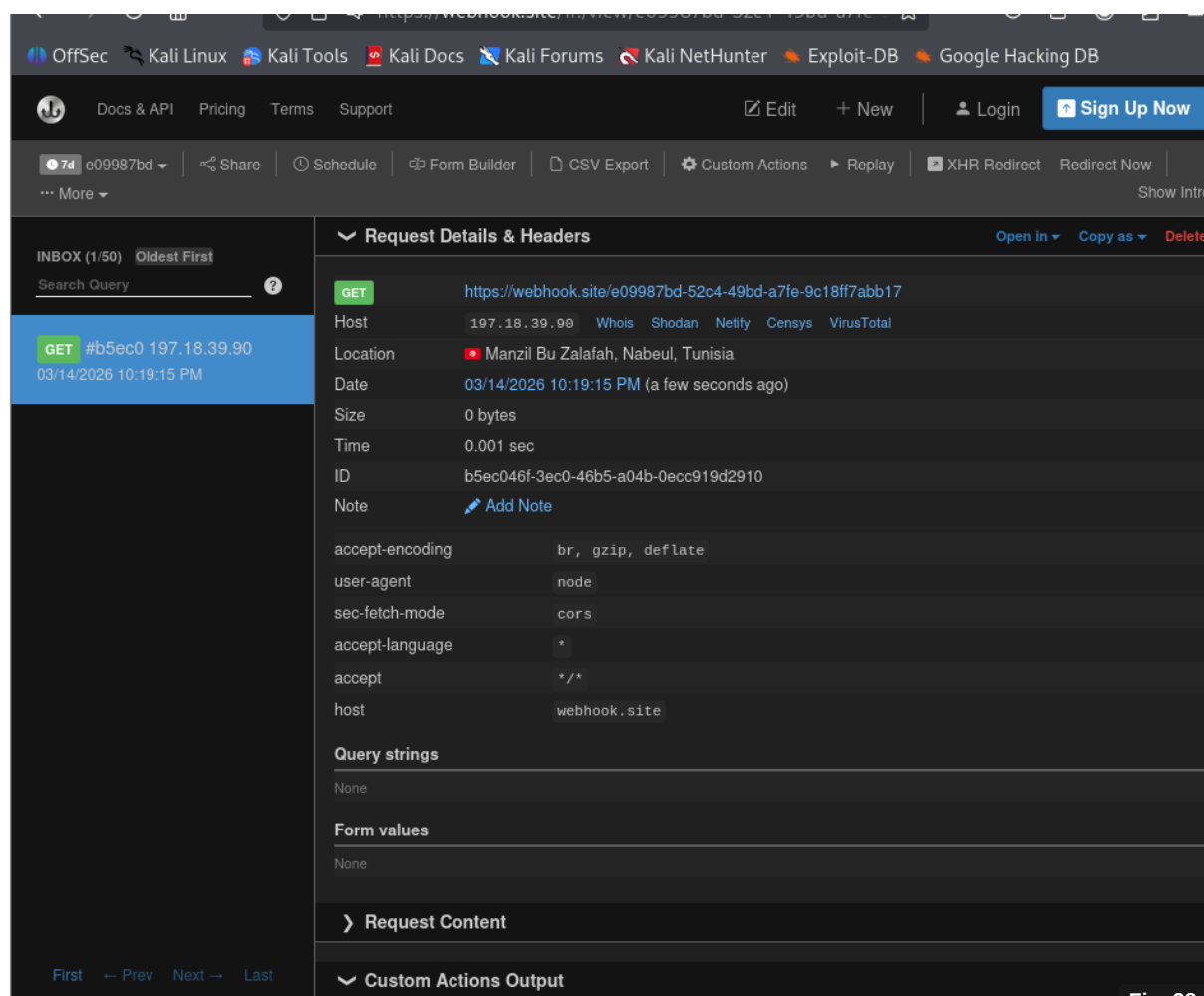


Fig. 38

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

le serveur visite un lien contrôlé →SSRF.

Impact

Accès aux services internes, analyse du réseau interne, contournement des pare-feu, accès aux métadonnées d'infrastructure en nuage (AWS, GCP, Azure).

Recommandations de remédiation

- Valider et assainir toutes les URL fournies par l'utilisateur
- Utiliser une liste blanche des domaines autorisés
- Bloquer les requêtes vers les plages d'adresses IP privées
- Désactiver les redirections HTTP non nécessaires

12. Conclusion et plan d'action

L'analyse de l'application OWASP Juice Shop révèle un panorama complet des risques de sécurité propres aux applications web modernes. Les vulnérabilités identifiées couvrent l'intégralité du classement OWASP Top 10 2021, avec des impacts allant de la divulgation d'informations à la compromission totale du système.

Priorités immédiates (0-30 jours)

- Corriger les injections SQL et mettre en place des requêtes paramétrées
- Sécuriser l'authentification : limitation du débit, MFA, JWT sécurisé
- Implémenter un contrôle d'accès basé sur les rôles (RBAC)
- Activer HTTPS/TLS et configurer les en-têtes de sécurité

Actions à moyen terme (30-90 jours)

- Mettre à jour toutes les dépendances vulnérables
- Déployer un WAF et un système de journalisation centralisé (SIEM)
- Effectuer une modélisation des menaces sur l'architecture
- Former les équipes de développement à la sécurité applicative

Actions à long terme (> 90 jours)

- Intégrer des tests de sécurité dans le pipeline d'intégration continue (SAST/DAST)
- Réaliser des audits de sécurité réguliers et des tests d'intrusion
- Mettre en place un programme de divulgation responsable des vulnérabilités
- Obtenir une certification de conformité (ISO 27001, SOC 2)